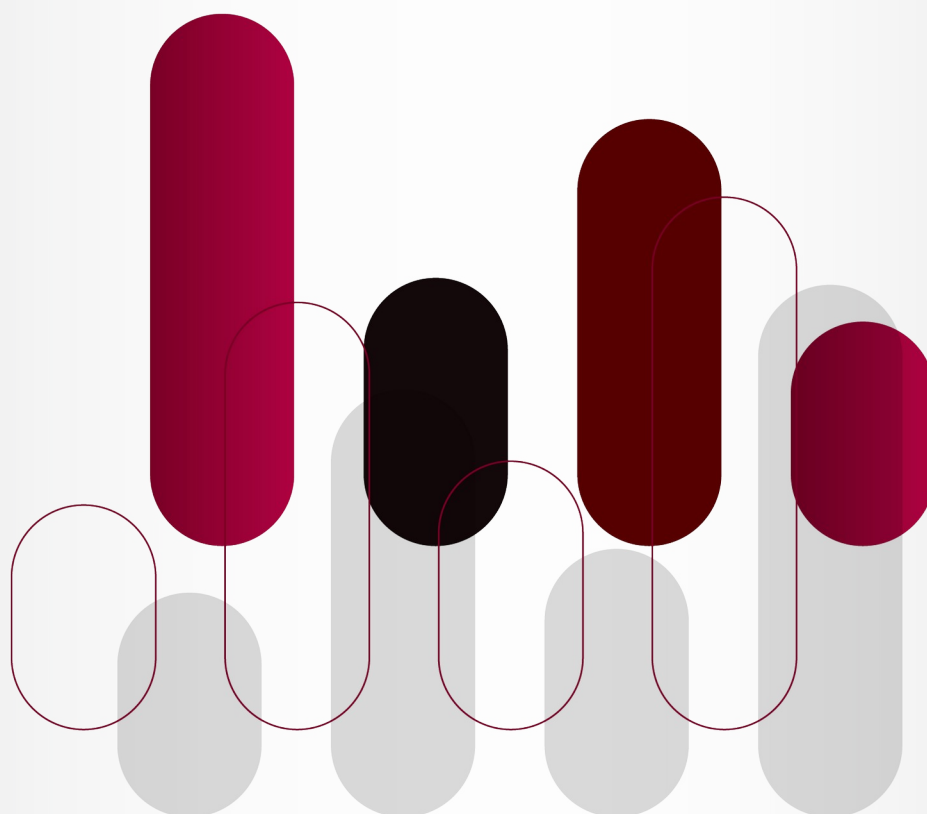




OneBank Camunda Portal Penetration Testing Report



**Web Application
Penetration Testing
Report**

Table of Contents

1.0 Document Control.....	1
1.1 Document Details.....	1
1.2 Diffusion List.....	1
1.3 Document History.....	1
2.0 Executive Summary.....	2
2.1 Project Objective.....	2
2.2 Disclaimer.....	3
2.3 Assessment Methodology.....	4
2.4 Summary of iSec Web Penetration Testing Check List.....	5
2.5 Summary of OWASP Top Ten Check List.....	5
2.6 Findings Distribution.....	6
2.7 Findings Distribution Chart.....	6
2.8 Risk Criteria.....	7
2.8.1 Exploitation Complexity.....	7
2.8.2 Risk Level Calculation.....	9
2.8.3 Risk Level Calculation.....	9
2.9 Summary of Findings.....	10
3.0 Project Description.....	11
3.1 Scope of work.....	11
3.1.1 Testing Scope.....	11
3.1.2 Scope Functions.....	11
3.1.3 Provided Credentials.....	11
3.2 Testing Constraints and Limitations.....	12
3.3 Report Organization.....	12
4.0 Check List.....	13
4.1 iSec Web Penetration Testing Checklist.....	13
4.2 OWASP Web Top 10 Check List.....	15
4.3 iSec Role in Remediation Phase.....	16
5.0 Vulnerability Findings.....	17
5.1 Camunda Portal - https://portal.onebank.example/camunda	17
5.1.1 SQL Injection in Login Form.....	17
Proof Of Concept.....	18
5.1.2 IDOR on Invoice Download.....	19
Proof Of Concept.....	20
5.1.3 Server Header Disclosure.....	21
Proof Of Concept.....	22
6.0 Recommendation.....	23
7.0 Appendix.....	24
7.1 Appendix I: Tools.....	24
7.2 Appendix II: CVSS Scoring Criteria.....	25

1.0 Document Control

1.1 Document Details

Document Title	OneBank Camunda Portal Penetration Testing Report v1.0
Classification	Confidential
Description	This document includes technical details of vulnerabilities and their exploits.
Date of Issue	September 20, 2026

1.2 Diffusion List

Contact Name	Contact Title	Contact Email
Ahmed Ali	Chief Information Security Officer	a.ali@onebank.example
Sara Mostafa	Head of Application Security	s.mostafa@onebank.example
Omar Khaled	IT Audit Manager	o.khaled@onebank.example

1.3 Document History

Version	Report Type	Start Date	End Date	Author	Description
1.0	Testing	21/04/2026	02/05/2027	System Administrator	Initial Test
		02/01/2025	02/01/2025	Eng. Sara M.	First Reviewer
		03/01/2025	03/01/2025	Eng. Omar K.	Second Reviewer
		04/01/2025	04/01/2025	Eng. Hany F.	Approving

2.0 Executive Summary

2.1 Project Objective

iSec performed **Initial Test Grey box** web application penetration testing on **Camunda Portal**. The purpose of this security assessment is to identify the application vulnerabilities and weakness. iSec's penetration testers adhere to a structured methodology, drawing inspiration from industry-standard frameworks, including but not limited to the OWASP Top 10, OWASP Web Security Testing Guide (WSTG), OSSTM (The Open-Source Security Testing Methodology Manual), and NIST SP 800-115 (National Institute of Standards and Technology).

This flexible methodology ensures a thorough examination of potential risks, allowing for tailored assessments based on specific client needs and encompassing broader industry best practices. Responding to a client request, the penetration testing engagement was initiated after working hours, minimizing the impact on the server load, given the production environment's sensitivity.

This strategy will imitate an attacker's tactics by making use of many of the same easily available tools such as Nmap, Metasploit, Burp suite, and more. As the process unfolds, we plan to dive deeper, incorporating more advanced techniques to identify additional attack surfaces.

iSec's approach to this security testing was meticulously conducted through extensive manual testing procedures, along with the use of automated tools and report the findings at the end of the engagement. The assessment seeks to enhance the overall security of the web application through various objectives. These include conducting vulnerability scanning, improving access controls, ensuring robust authentication and session management, and addressing potential weaknesses that could compromise the confidentiality of information. Collectively, these efforts aim to fortify the application against a range of security risks.

The results presented in this report represent the situation in a limited time frame. Any changes in the current architecture, code, and/or configurations might lead to different results if the test is to be conducted again.

Because of the time limitation and the nature and sensitivity of the tested servers, some exploitation techniques were excluded. This penetration test does not include:

- Social Engineering attacks
- Denial-of-Service attacks

2.2 Disclaimer

This report contains confidential information that is intended only for **OneBank**. We hereby disclaim all liability for any damages resulting from third-party alterations and prohibit any unauthorized use, disclosure, or copying.

Due to timing limitations, not every security measure was thoroughly assessed. The findings, recommendations, and risks are current as of the time of submission and are based on the data gathered during the assessment; they might not be updated to reflect recent developments.

The allocated man-days for testing directly impact the findings. Increasing the time allocated for testing enhances the likelihood of identifying a greater number of findings, as more time allows for a more thorough and comprehensive assessment.

This report's future projections could change as a result of modifications to the infrastructure architecture. The use of the stated targeted applications or systems may result in financial loss to the respected company, and the report makes no guarantees regarding this matter. iSec is not absolute, and policy reviews, upkeep, and regular monitoring are essential.

iSec provides no warranties, representations, or legal certifications for tested applications or systems.

2.3 Assessment Methodology

iSec's methodology, our penetration testers adhere to a structured methodology, drawing inspiration from industry-standard frameworks, including but not limited to the **OWASP Top 10**, **OWASP Web Security Testing Guide (WSTG)**, **OSSTM (The Open-Source Security Testing Methodology Manual)**, and **NIST SP 800-115 (National Institute of Standards and Technology)**. This flexible methodology ensures a thorough examination of potential risks, allowing for tailored assessments based on specific client needs and encompassing broader industry best practices. This strategy will imitate an attacker's tactics by making use of many of the same easily available tools.

Initially, it involves information gathering and threat modeling to understand the target application's architecture, potential vulnerabilities, and collect data related to the target scope. Subsequently, we move on to exploiting identified vulnerabilities uncovered during the preliminary steps. This involves a meticulous examination of user information, scrutinizing permissions, and assessing potential risks associated with unauthorized access to restricted paths.

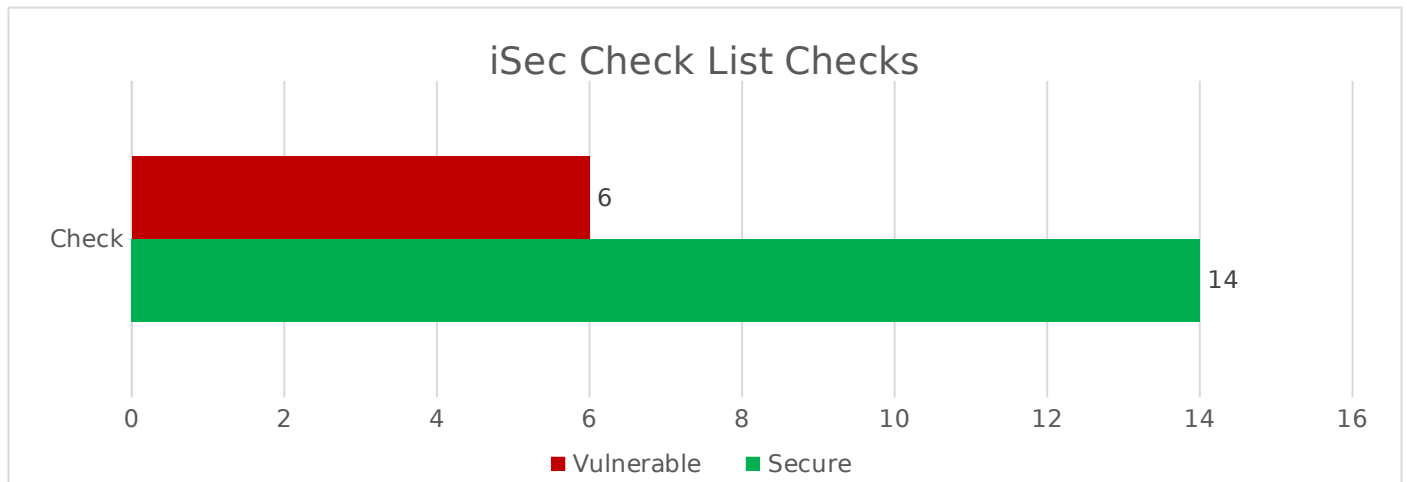
The actual testing phase includes vulnerability scanning, manual testing, and exploitation to validate identified issues. Throughout the process, adherence to OWASP WSTG ensures comprehensive coverage of testing scenarios, including authentication, authorization, input validation, and data security.

Finally, the findings are documented, providing clear and actionable recommendations for remediation, prioritized based on risk severity to assist in securing the web application effectively.

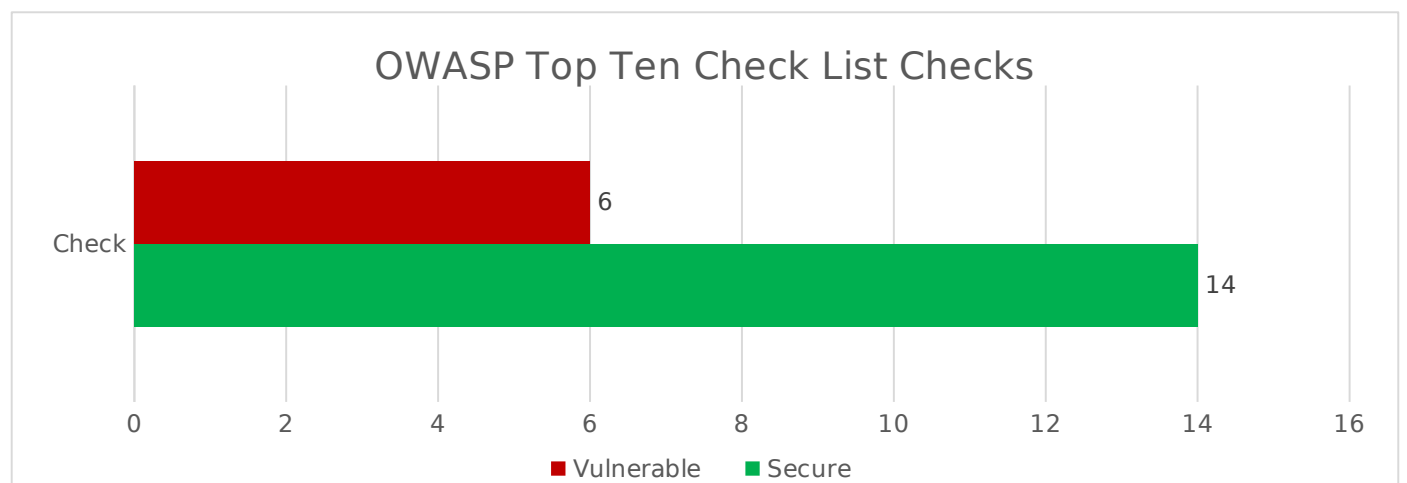
By systematically progressing through these steps, we ensure a thorough and methodical assessment, adhering to industry best practices and security standards.



2.4 Summary of iSec Web Penetration Testing Check List



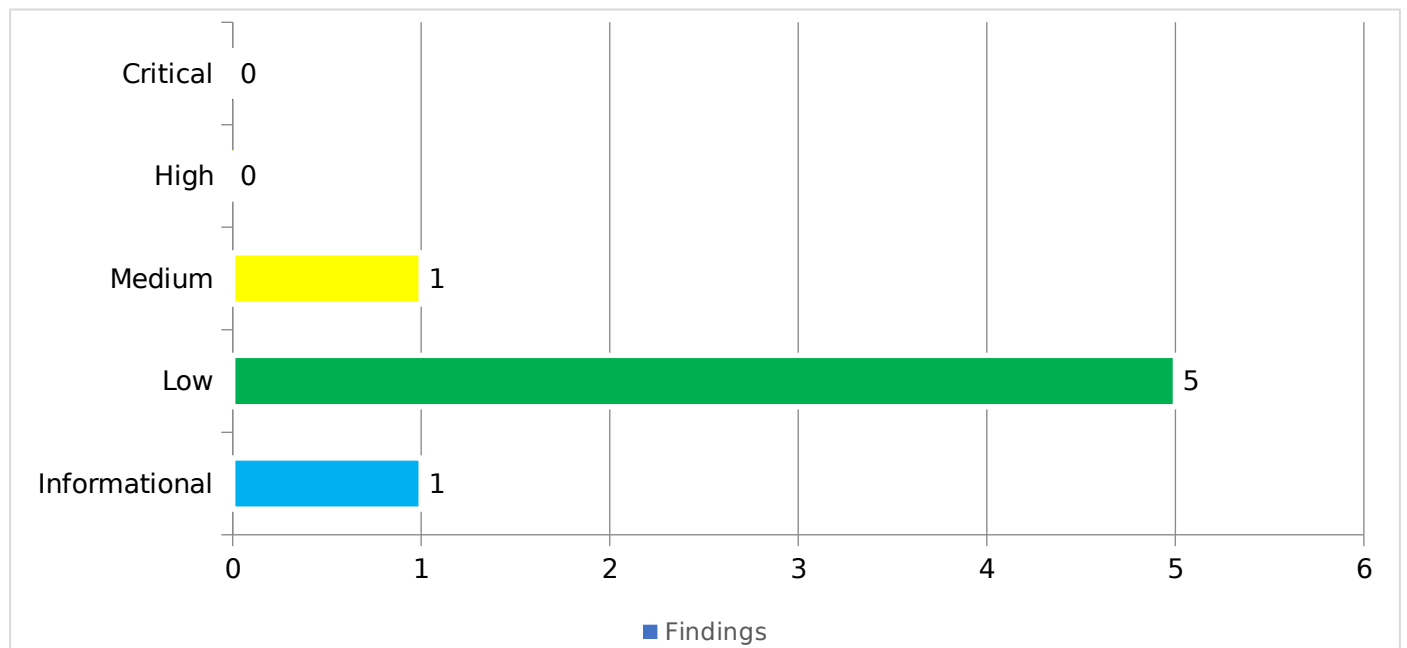
2.5 Summary of OWASP Top Ten Check List



2.6 Findings Distribution

Severity	Initial Test
Critical	1
High	1
Medium	0
Low	0
Informational	1

2.7 Findings Distribution Chart



2.8 Risk Criteria

Each finding identified in this security assessment is rated against both the impact of the finding and how easy it would be for an attacker to exploit. The fix rating provides a guide to the effort required to resolve the finding. Type specifies in which Classification type the finding comes under. The overall rating for the finding is calculated based on the finding's impact and ease ratings.

Semiquantitative	CVSS	Description
Critical	9.0 - 10.0	The vulnerability is exposed and exploitable, and its exploitation could result in severe impacts. Relevant security control or other remediation is not implemented and not planned; or no security measure can be identified to remediate the vulnerability.
High	7.0 - 8.9	The vulnerability is of high concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its Relevant security control or other remediation is planned but not implemented; compensating controls are in place and at least minimally effective.
Medium	4.0 - 6.9	The vulnerability is of moderate concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its Relevant security control or other remediation is partially implemented and somewhat effective.
Low	0.1 - 3.9	The vulnerability is of minor concern, but effectiveness of remediation could be improved. Relevant security control or other remediation is fully implemented and somewhat effective.
Informational	0.0	The vulnerability is not of concern. Relevant security control or other remediation is fully implemented, assessed, and effective.

2.8.1 Exploitation Complexity

Value	Description
Complex	An attacker with an advanced knowledge and reasonable experience with a lot of effort and personal developed tools/scripts can exploit this vulnerability.
Moderate	An attacker with some specific knowledge using a combination of automated tools, operating system tools and open-source tools can exploit this vulnerability.
Easy	An attacker with minimal or basic knowledge depending on automated tools or open-source tools can exploit this vulnerability.
Trivial	Anyone with no knowledge with the help of an automated tool can

exploit this vulnerability.

2.8.2 Risk Level Calculation

Complexity Impact	Trivial	Easy	Moderate	Complex
Critical	Critical	Critical	High	High
High	Critical	High	High	Medium
Medium	High	Medium	Medium	Low
Low	Medium	Medium	Low	Low

2.8.3 Risk Level Calculation

		Impact How severe would the outcomes be if the risk occurred?				
		Insignificant 1	Minor 2	Significant 3	Major 4	Severe 5
Probability What is the probability the risk will happen?	Rare 1	Very Low 1	Very Low 2	Low 3	Medium 4	Medium 5
	Unlikely 2	Very Low 2	Low 4	Medium 6	Medium 8	High 10
	Moderate 3	Low 3	Medium 6	Medium 9	High 12	Very High 15
	Likely 4	Medium 4	Medium 8	High 12	Very High 16	Extreme 20
	Almost Likely 5	Medium 5	High 10	Very High 15	Extreme 20	Extreme 25

2.9 Summary of Findings

The below table determine the summary of penetration testing final result.

#	Vulnerability	Risk	CVSS 3.1	Affected URL	Affected User	Status
1.	SQL Injection in Login Form	Critical	9.8	https://portal.onebank.example/login?user=a&x=1	Unauthenticated	Initial Test
2.	IDOR on Invoice Download	High	7.5	https://portal.onebank.example/api/invoices/{id}	Normal user	Initial Test
3.	Server Header Disclosure	Informational	0.0	https://portal.onebank.example/	-	Initial Test

3.0 Project Description

3.1 Scope of work

This penetration testing **Initial Test** was conducted on **Camunda Portal** as a **Grey Box** penetration test, aimed at evaluating the effectiveness of the security features and controls implemented on the application. Consequently, the resulting report will provide an overview of the current security state of the program, detailing the identified vulnerabilities along with recommended security mitigations. By assigning risk ratings to each vulnerability, the management will be empowered to make informed decisions regarding the appropriate measures to address the identified risks.

3.1.1 Testing Scope

Application Name	Application URL	Version	Environment Type
Camunda Portal (Initial Test)	https://portal.onebank.example/camunda	2.3	UAT

3.1.2 Scope Functions

In Scope Functions	
Login Money transfer Beneficiary management	
Out Of Scope Functions	
Functions Names	Reason
Admin back office - requested by client	

3.1.3 Provided Credentials

User	Description
user1 - Normal User Account admin1 - Admin Account	

3.2 Testing Constraints and Limitations

During this engagement, we encountered no limitations.

3.3 Report Organization

This report is organized into six sections, as follows:

Section	Description
Executive Summary	Introductory section targeting non-technical management.
Project Description	Describing the project scope and objective.
Methodology & checklist	Describing the assessment methodology & checklist.
Detailed findings	Detailed low-level findings for each system within the scope.
Attack Scenarios	Details of the assessment scenarios.
Conclusion	Summary of recommendation and suggested way forwards.

4.0 Check List

4.1 iSec Web Penetration Testing Checklist

The iSec Web Penetration Testing Checklist is a structured guide based on the Web Security Testing Guide (WSTG) and iSec's methodology, to help penetration testers thoroughly assess web applications for security vulnerabilities. Covering key areas like input validation, authentication, and access control, it ensures no aspect is overlooked, enhancing the efficiency and consistency of web application security testing.

#	Attack Type	Done	Status
1.	WAF Bypass	N/A	N/A
2.	Content Security Policy (CSP)	Done	Not Vulnerable
3.	Secure Flags	Done	Not Vulnerable
4.	Cross-Origin Resource Sharing (CORS)	Done	Not Vulnerable
5.	HTTP Security Headers (like Strict-Transport-Security)	Done	Not Vulnerable
6.	HTTP Methods	Done	Vulnerable
7.	Security Misconfiguration	Done	Not Vulnerable
8.	Information Disclosure	Done	Vulnerable
9.	Username Enumeration	Done	Not Vulnerable
10.	Guessable/Default Credentials	Done	Not Vulnerable
11.	Brute Force	Done	Not Vulnerable
12.	Password Policy	Done	Not Vulnerable
13.	Multi-Factor Authentication (MFA)	Done	Not Vulnerable
14.	Logout Functionality	Done	Not Vulnerable
15.	Directory Traversal	Done	Not Vulnerable
16.	Privilege Escalation	Done	Not Vulnerable
17.	Authorization Bypass	Done	Vulnerable
18.	Session Management Schema	Done	Not Vulnerable
19.	Cookies Attributes	Done	Not Vulnerable
20.	Cross-Site Request Forgery (CSRF)	Done	Not Vulnerable
21.	SQL Injection	Done	Not Vulnerable
22.	Cross-Site Script Inclusion (XSSI)	Done	Not Vulnerable
23.	XML External Entity (XXE) Injection	Done	Not Vulnerable

24.	Command Injection	Done	Not Vulnerable
25.	Cross-Site Scripting (XSS)	Done	Not Vulnerable
26.	HTTP Parameter Pollution	Done	Not Vulnerable
27.	Insecure Deserialization	Done	Not Vulnerable
28.	Local File Inclusion (LFI)	Done	Not Vulnerable
29.	Insufficient Input Validation	Done	Not Vulnerable
30.	Server-Side Request Forgery (SSRF)	Done	Not Vulnerable
31.	Business Logic Flaws	Done	Not Vulnerable
32.	Transaction Integrity	Done	Not Vulnerable
33.	Rate Limiting and DoS Controls	Done	Not Vulnerable
34.	Client-Side URL Redirection	Done	Not Vulnerable
35.	JavaScript Execution	Done	Not Vulnerable
36.	HTML5 Storage	Done	Not Vulnerable
37.	URL Manipulation	Done	Not Vulnerable
38.	Race Conditions	Done	Not Vulnerable
39.	Insufficient Authorization Checks	Done	Not Vulnerable
40.	Insecure Direct Object References (IDOR)	Done	Not Vulnerable
41.	Insecure Session Storage	Done	Not Vulnerable
42.	Session Hijacking	Done	Not Vulnerable
43.	Outdated Components	Done	Not Vulnerable
44.	Unrestricted File Upload	Done	Not Vulnerable
45.	Insecure Design	Done	Not Vulnerable
46.	Misconfigured SSL/TLS (Weak Ciphers, SSL/TLS Version)	Done	Not Vulnerable
47.	Presence of Debugging or Diagnostic Information	Done	Not Vulnerable
48.	Sensitive Data Exposure	Done	Not Vulnerable
49.	Response Manipulation	Done	Not Vulnerable
50.	HTTP Response Splitting	Done	Not Vulnerable
51.	Unauthorized Remote Code Execution	Done	Not Vulnerable
52.	Improper Validation of File Upload Types	Done	Not Vulnerable

4.2 OWASP Web Top 10 Check List

#	Attack Type	Checks	Status
1.	A01:2025 - Broken Access Control	Done	Passed
2.	A02:2025 - Security Misconfiguration	Done	Passed
3.	A03:2025 - Software Supply Chain Failures	Done	Passed
4.	A04:2025 - Cryptographic Failures	Done	Passed
5.	A05:2025 - Injection	Done	Passed
6.	A06:2025 - Insecure Design	Done	Passed
7.	A07:2025 - Authentication Failures	Done	Passed
8.	A08:2025 - Software or Data Integrity Failures	Done	Passed
9.	A09:2025 - Logging & Alerting Failures	Done	Passed
10.	A10:2025 - Mishandling of Exceptional Conditions	Done	Passed

4.3 iSec Role in Remediation Phase

Penetration testing evaluates an organization's ability to protect its networks, applications, endpoints and users from attempts to circumvent its security controls to gain unauthorized or privileged access to protected assets. Test results validate the risk posed by specific security vulnerabilities or flawed processes, the results will be communicated to the involved teams in a way that allows team to more intelligently prioritize remediation, apply needed security patches and allocate security resources more efficiently to ensure that they are available when and where they are needed most. iSec team is committed to clearly communicate the findings and recommended counter measures to all parties responsible for the remediation. iSec team will provide the required support to team while implementing the recommended remediation activities.

5.0 Vulnerability Findings

5.1 Camunda Portal - <https://portal.onebank.example/camunda>

5.1.1 SQL Injection in Login Form

Severity	CVSS 3.1	Status
Critical	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)	Initial Test
Affected Assets	▪ https://portal.onebank.example/login?user=a&x=1	
OWASP Top Ten	A04 - Insecure Design	
iSec Check List	SQL Injection, Insufficient Input Validation	
Description	The application concatenates untrusted request parameters directly into SQL statements. The username and password parameters of the login request, the search parameter and the report identifier were confirmed vulnerable: a crafted value changes the query, bypasses authentication or returns rows that belong to other users. Every payload was replayed three times from a clean session and produced the same result, which rules out caching or a transient backend fault as the cause of the observed behaviour.	
Impact	Full read access to the customer database.	
Recommendation	• Use parameterised queries.	

Proof Of Concept

Reproduction steps:

1. Browse to the login page and intercept the request with **burpsuite**.
2. Replace the **username** parameter with the payload shown in the request below.
3. Confirm the export at <https://app.example.com/reports/export?token=AAAABBBBCCCCDDDDDEEEEEFFFFGGGGHHHHIIIIJJJJKKKK&format=csv> returns rows for another tenant.

```
POST /auth/login HTTP/1.1
Host: app.example.com
Content-Type: application/x-www-form-urlencoded

username=' OR '1'='1&password=irrelevant
```

Control review (table pasted without an editor class):

Control	Status	Evidence
Parameterised queries	Fail	String concatenation in AuthDao
Input validation	Fail	No allowlist on username
Web application firewall	Partial	Blocks UNION keyword only
Error handling	Fail	Stack trace returned to client

Evidence:



Figure 1: authentication bypassed with the payload above.

5.1.2 IDOR on Invoice Download

Severity	CVSS 3.1	Status
High	7.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)	Initial Test
Affected Assets	https://portal.onebank.example/api/invoices/{id}	
OWASP Top Ten	A01 - Broken Access Control	
iSec Check List	Insecure Direct Object References (IDOR)	
Description	Invoice IDs are sequential and not authorised.	
Impact	Disclosure of other customers' invoices.	
Recommendation	Enforce ownership checks server side.	

Proof Of Concept

1. Log in as user1.
2. Request invoice 1002 belonging to user2.

5.1.3 Server Header Disclosure

Severity	CVSS 3.1	Status
Informational	0.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N)	Initial Test
Affected Assets	https://portal.onebank.example/	
OWASP Top Ten	A05 - Security Misconfiguration	
iSec Check List	Information Disclosure	
Description	The Server header reveals the product version.	
Impact	Eases reconnaissance.	
Recommendation	Suppress the Server header.	

Proof Of Concept

Observed in every HTTP response.

6.0 Recommendation

The following actions are recommended for you to improve the current security.

- Cover all the findings stated in this report.
- Update outdated libraries.

7.0 Appendix

7.1 Appendix I: Tools

This appendix outlines the various tools used throughout the assessment.

Tool	Purpose
Nmap	Nmap is used to discover hosts and services on a computer network and operating system detection. by sending packets and analyzing the responses.
Acunetix	Acunetix web vulnerabilities, Acunetix aimed to offer an automated tool to scan web applications to identify and resolve security issues. Simply put, Acunetix is an all-in-one website security scanner.
Burp suite professional	Burp Suite is an integrated platform/graphical tool for performing security testing of web applications. Its various tools work seamlessly together to support the entire testing process, from initial mapping and analyzing of an application's attack surface, discover findings and exploiting security vulnerabilities.
Ffuf	Ffuf is a fast web fuzzer written in Go that allows typical directory discovery, virtual host discovery (without DNS records) and GET and POST parameter fuzzing.
Nuclei	Nuclei is used to send requests across targets based on a template, leading to zero false positives and providing fast scanning on a large number of hosts. Nuclei offers scanning for a variety of protocols, including TCP, DNS, HTTP, SSL, File, Whois, Websocket, Headless etc. With powerful and flexible templating, Nuclei can be used to model all kinds of security checks.

7.2 Appendix II: CVSS Scoring Criteria

This appendix outlines the CVSS base scores calculations.

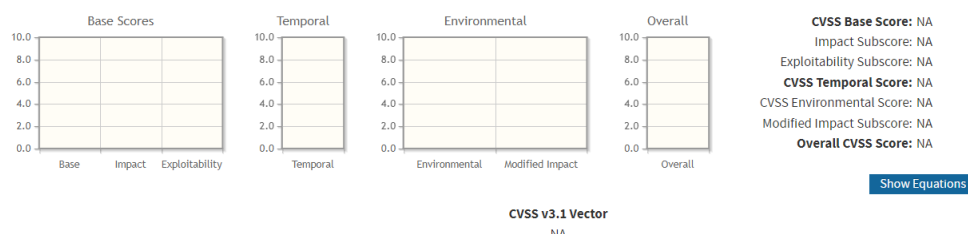
Impact Metrics	Description
Confidentiality Impact (C)	Represents the impact on confidentiality, with values None (N), Low (L), or High (H).
Integrity Impact (I)	Describes the impact on integrity, with values None (N), Low (L), or High (H).
Availability Impact (A)	Indicates the impact on availability, with values None (N), Low (L), or High (H).

Exploitability Metrics	Description
Attack Vector (AV)	Describes how the vulnerability is exploited, ranging from Local (L) to Network (N) attacks.
Attack Complexity	Specifies the complexity of the attack required, from Low (L) to High (H).
Privileges Required (PR)	Defines the privileges an attacker needs, ranging from None (N) to High (H).
User Interaction (UI)	Indicates whether user interaction is required, with values None (N) or Required (R).

The Base Score is calculated using the formula:

This formula combines the Impact and Exploitability metrics, ensuring a comprehensive evaluation of the vulnerability's severity. The Base Score provides a standardized way to prioritize security efforts, enabling organizations to effectively manage their vulnerabilities.

An online CVSS Calculator tool is used to perform the calculation: <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>



Base Score Metrics	
Exploitability Metrics	
Attack Vector (AV)*	
☐ Network (AV:N) ☐ Adjacent Network (AV:A) ☐ Local (AV:L) ☐ Physical (AV:P)	
Attack Complexity (AC)*	
☐ Low (AC:L) ☐ High (AC:H)	
Privileges Required (PR)*	
☐ None (PR:N) ☐ Low (PR:L) ☐ High (PR:H)	
User Interaction (UI)*	
☐ None (UI:N) ☐ Required (UI:R)	
Scope (S)*	
☐ Unchanged (S:U) ☐ Changed (S:C)	
Impact Metrics	
Confidentiality Impact (C)*	
☐ None (C:N) ☐ Low (C:L) ☐ High (C:H)	
Integrity Impact (I)*	
☐ None (I:N) ☐ Low (I:L) ☐ High (I:H)	
Availability Impact (A)*	
☐ None (A:N) ☐ Low (A:L) ☐ High (A:H)	

* - All base metrics are required to generate a base score.